

SIMATS ENGINEERING

EH-CO3-AT2 | Assessment Tool 2 – Port Scanning Challenge

Course: Ethical Hacking (ITA14) | CO3: Analyze network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities. (BT4)

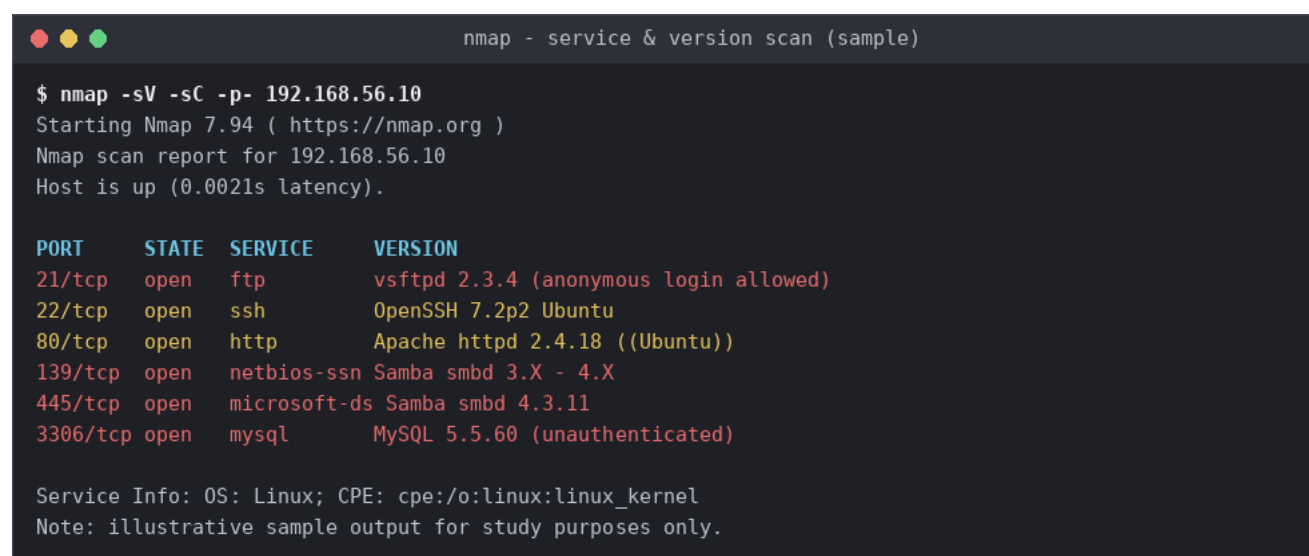
Q1. How would you identify and prioritize vulnerabilities after discovering multiple open ports during a port scan? Explain your approach.

Answer:

Discovering open ports is only the starting point of a vulnerability assessment; the real value comes from turning raw scan output into a prioritized, evidence-based remediation plan. The process below follows the standard reconnaissance-to-remediation workflow used in professional penetration testing and vulnerability management programmes.

Step 1 – Service and Version Identification (Fingerprinting)

- Run a service/version detection scan (e.g. **nmap -sV -sC -p-**) on every open port to identify the exact daemon, version, and banner instead of assuming a service purely from the port number (port 8080 is not always HTTP, for example).
- Fingerprint the underlying operating system and patch level (e.g. **nmap -O**) because the same service can carry very different risk depending on the platform it runs on.
- Enumerate further where the protocol allows it – e.g. SMB share listing, SNMP community strings, HTTP headers/technology stack – to build a complete picture of the attack surface.



```
nmap - service & version scan (sample)

$ nmap -sV -sC -p- 192.168.56.10
Starting Nmap 7.94 ( https://nmap.org )
Nmap scan report for 192.168.56.10
Host is up (0.0021s latency).

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4 (anonymous login allowed)
22/tcp    open  ssh          OpenSSH 7.2p2 Ubuntu
80/tcp    open  http         Apache httpd 2.4.18 ((Ubuntu))
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X
445/tcp   open  microsoft-ds Samba smbd 4.3.11
3306/tcp  open  mysql        MySQL 5.5.60 (unauthenticated)

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
Note: illustrative sample output for study purposes only.
```

Fig. 1 - Sample nmap -sV -sC output showing service, version and risk flags (illustrative)

Step 2 – Vulnerability Correlation

- Cross-reference each identified service/version against vulnerability databases such as the National Vulnerability Database (NVD), CVE Details, or vendor security advisories to find known CVEs.
- Use automated vulnerability scanners (e.g. Nessus, OpenVAS, Qualys) to map banner information to known exploits, missing patches, and common misconfigurations at scale.
- Check exploit repositories (e.g. Exploit-DB, Metasploit modules, GitHub PoCs) to see whether a working, weaponized exploit exists for a discovered version – this materially changes the urgency of the finding.

- Validate findings manually where feasible (banner grabbing with **nc/telnet**, checking config files) to eliminate false positives before they reach the report.

Step 3 – Risk-Based Prioritization

- **Severity (CVSS):** Use the Common Vulnerability Scoring System to rate each finding's base score – exploitability (attack vector, complexity, privileges required) combined with impact (confidentiality, integrity, availability).
- **Exposure:** A vulnerable service reachable from the internet is far more urgent than the identical service reachable only from a segmented internal VLAN.
- **Asset criticality:** Weight findings by business value – a flaw on a domain controller, payment gateway, or production database outranks the same flaw on a disposable test VM.
- **Ease of exploitation:** Ports with public, weaponized exploits or default/weak credentials are prioritized above theoretical issues that require complex conditions to trigger.
- **Chaining potential:** Consider whether a lower-severity finding (e.g. an information-disclosure port) could be combined with another to enable a higher-impact multi-stage attack.
- **Compensating controls:** A vulnerability behind a WAF, IPS, or strict network segmentation may be de-prioritized relative to the same flaw with no compensating control.

Illustrative Risk Matrix

Finding	CVSS	Exposure	Priority
Anonymous FTP login (vsftpd 2.3.4, backdoored version)	10.0	Internet-facing	Critical
Outdated SMB (Samba) allowing enumeration	8.1	Internet-facing	High
Unauthenticated MySQL bound to 0.0.0.0	9.1	Internet-facing	Critical
OpenSSH slightly outdated, password auth only	5.3	Internal only	Medium
Apache banner reveals version (info disclosure)	3.1	Internet-facing	Low

Step 4 – Documentation and Remediation Planning

- Record each finding with the port, service, CVE reference, CVSS score, evidence (screenshot/output), and a clear recommended fix, mapped directly into a remediation backlog or ticketing system.
- Group similar findings (e.g. outdated TLS across multiple hosts) so they can be patched in a single coordinated change window rather than one ticket per port.
- Set remediation SLAs by severity – e.g. Critical findings fixed within 24–72 hours, High within 7 days, Medium within 30 days – and track them to closure with a re-scan.
- Present an executive summary (business risk, in plain language) alongside the technical detail so non-technical stakeholders understand why remediation is urgent.

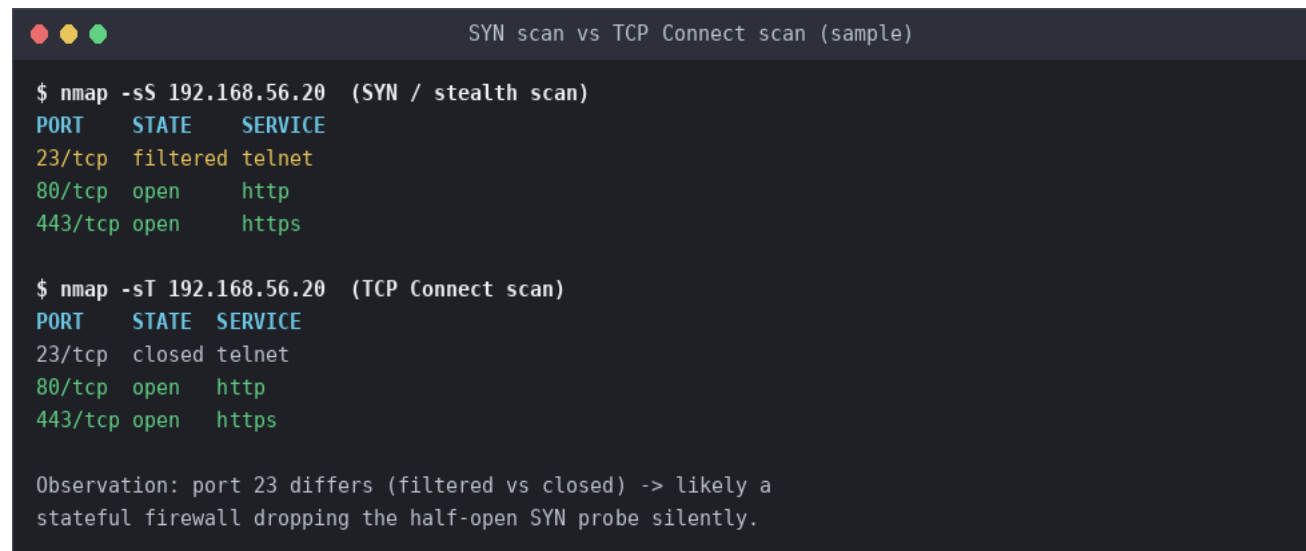
In short, the approach follows **Discover** → **Fingerprint** → **Correlate to known vulnerabilities** → **Score by risk (severity × exposure × asset value)** → **Remediate the highest-risk items first** → **Verify by re-scanning**, rather than treating every open port as equally dangerous.

Note: All scan commands and outputs shown in this document are illustrative samples created for academic explanation. Any real scanning must only be performed on systems you own or are explicitly authorized in writing to test.

Q2. A SYN scan and a TCP Connect scan produce different results on the same target. What factors could cause this difference, and how would you verify the findings?

Answer:

A SYN scan (**nmap -sS**) sends a SYN packet and evaluates only the response – SYN/ACK (open), RST (closed), or no response/ICMP unreachable (filtered) – without completing the TCP three-way handshake; it then sends a RST to tear the half-open connection down. A TCP Connect scan (**nmap -sT**) instead uses the operating system's **connect()** system call, completing the full handshake like a normal application would. Because the two techniques interact with the target and any in-path devices differently, they can legitimately report different port states for the same host.



```
SYN scan vs TCP Connect scan (sample)

$ nmap -sS 192.168.56.20 (SYN / stealth scan)
PORT      STATE      SERVICE
23/tcp    filtered  telnet
80/tcp    open      http
443/tcp   open      https

$ nmap -sT 192.168.56.20 (TCP Connect scan)
PORT      STATE      SERVICE
23/tcp    closed    telnet
80/tcp    open      http
443/tcp   open      https

Observation: port 23 differs (filtered vs closed) -> likely a
stateful firewall dropping the half-open SYN probe silently.
```

Fig. 2 - Sample SYN scan vs TCP Connect scan showing a discrepancy on port 23 (illustrative)

Possible Causes of the Discrepancy

- **Firewall / IDS behaviour:** Some firewalls and intrusion prevention systems specifically detect and drop half-open (SYN-only) connections while allowing fully-established TCP connections through, or vice versa – this is the single most common cause of the difference.
- **Stateful inspection devices:** A stateful firewall tracks connection state differently for a completed handshake versus a half-open one, and may reset or silently drop incomplete connections faster.
- **Rate limiting and connection thresholds:** A Connect scan's fully-established sessions consume connection-table resources on the target/firewall and can trigger rate limiting that a stealthier SYN scan does not trigger, changing the results mid-scan.
- **Privilege level of the scanning tool:** A SYN scan needs raw-socket (root/admin) privileges; if nmap silently falls back to a Connect scan because it lacks privileges, the apparent "difference" is actually a configuration artefact, not a real network behaviour.
- **Network instability or packet loss:** Scans run at different times can be affected by transient congestion, load balancers routing to different backend hosts, or intermittent packet loss.
- **Application-layer response behaviour:** Some services only respond (or log/alert) after a completed handshake, so a SYN-only probe may appear as filtered while a full connection reveals it as genuinely open.
- **Host-based firewall vs network firewall mismatch:** The operating system's own firewall (iptables/Windows Firewall) may treat half-open vs full connections differently from an upstream network firewall, producing conflicting evidence from the two scan types.

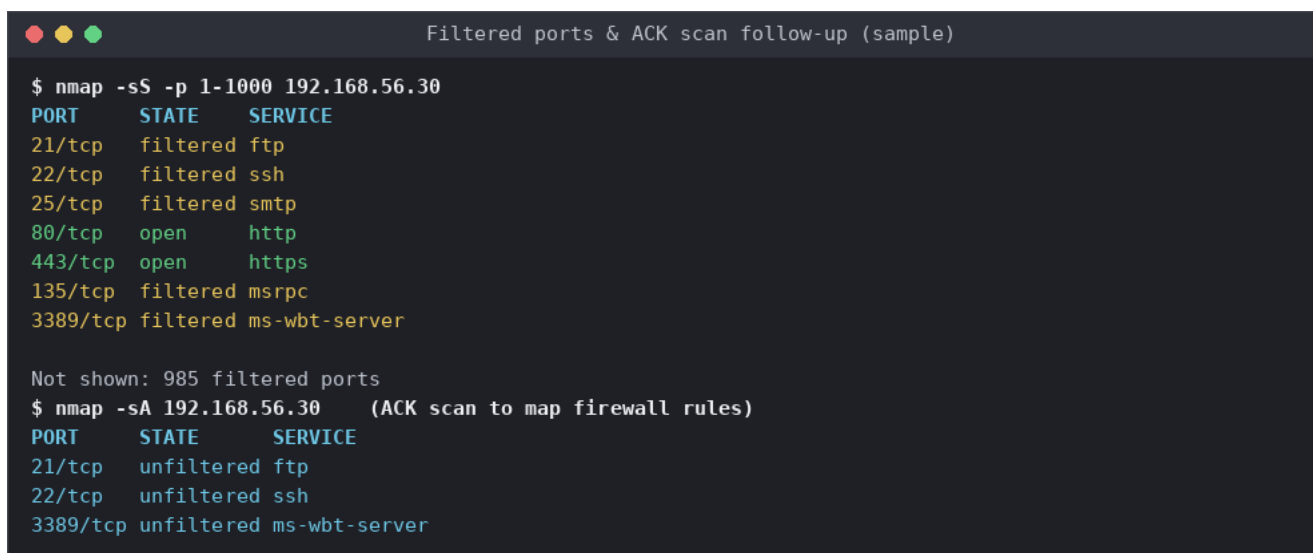
Verifying the Findings

- Re-run both scans multiple times, at different times of day, to rule out transient network conditions or load-balancing effects.
- Run the scans with elevated (root/admin) privileges to confirm the SYN scan is genuinely using raw sockets and not silently downgrading to a Connect scan.
- Use a third, independent technique – an ACK scan, a UDP scan, or a completely different tool (e.g. masscan, hping3, Zenmap) – as a cross-check against the nmap results.
- Perform a manual connection test with **telnet**, **nc** (netcat), or **curl** against the specific port to directly confirm whether a full application-level connection succeeds.
- Capture traffic with Wireshark or tcpdump during both scans to see exactly how the target and any in-path devices respond (SYN-ACK, RST, or silence) and confirm where filtering is happening.
- If authorized, correlate the results with server-side logs or with the system administrator/firewall rule-base to confirm the true state of the service.

Q3. During a port scan, most ports appear as “filtered.” What security mechanisms might be responsible, and what additional techniques would you use to gather more information?

Answer:

In nmap terminology, a “filtered” result means the scanner could not determine whether the port is open or closed, because no response was received, or an ICMP unreachable/administratively-prohibited error was returned. This is a strong indicator that an active security control – not the absence of a service – is responsible, and it calls for deeper investigation rather than treating the port as simply closed.



```
Filtered ports & ACK scan follow-up (sample)

$ nmap -sS -p 1-1000 192.168.56.30
PORT      STATE    SERVICE
21/tcp    filtered ftp
22/tcp    filtered ssh
25/tcp    filtered smtp
80/tcp    open     http
443/tcp   open     https
135/tcp   filtered msrpc
3389/tcp  filtered ms-wbt-server

Not shown: 985 filtered ports
$ nmap -sA 192.168.56.30 (ACK scan to map firewall rules)
PORT      STATE    SERVICE
21/tcp    unfiltered ftp
22/tcp    unfiltered ssh
3389/tcp  unfiltered ms-wbt-server
```

Fig. 3 - Sample scan showing filtered ports, followed by an ACK scan to map firewall behaviour (illustrative)

Likely Security Mechanisms

- **Firewalls (network or host-based):** Configured to silently drop (rather than reject) packets to non-permitted ports, which is the classic textbook cause of a “filtered” result.
- **Intrusion Detection/Prevention Systems (IDS/IPS):** May detect scanning behaviour signatures and dynamically block or rate-limit the scanning source's traffic mid-scan.
- **Access Control Lists (ACLs) on routers/switches:** Restrict which source addresses or subnets can reach certain ports, effectively hiding services from unauthorized scanners at the network layer.

- **Network Address/Port Translation and DMZ segmentation:** Internal services may simply not be routable at all from the scanning host's network position.
- **Rate limiting/traffic shaping:** Some devices throttle or silently drop ICMP/TCP responses once a threshold of probes is exceeded, making a busy or noisy scan appear more “filtered” than it actually is.
- **Endpoint security software:** Host firewalls (Windows Defender Firewall, iptables/nftables, ufw) configured to drop unsolicited inbound packets by default.
- **Honeypots / deception technology:** In some environments, deliberately filtered ports are part of a deception strategy to waste an attacker's time and trigger alerts.

Additional Techniques to Gather More Information

- **ACK scan (-sA):** Helps distinguish whether filtering is done by a genuine stateful firewall versus a simple stateless packet filter, by mapping which ports are blocked regardless of connection state.
- **Fragmented packets (-f) or decoy scans (-D):** Can sometimes evade simple filtering rules that inspect whole packets, revealing the true port state (only in an authorized, in-scope test).
- **Firewalk technique:** Uses controlled TTL manipulation to map a firewall's rule set and determine which ports it permits through to a downstream host.
- **Idle (zombie) scan (-sI):** Uses a third-party “idle” host's IP ID sequence to scan a target completely blind, which can sometimes bypass source-based filtering.
- **Scanning from multiple vantage points:** Comparing results from inside vs outside the network, or from an allow-listed IP, quickly reveals whether filtering is perimeter-based or host-based.
- **Timing and evasion options (-T0 to -T5, --scan-delay):** Slowing the scan down can avoid IDS/IPS rate-limiting thresholds and produce more accurate results.
- **UDP-specific probing and application-layer requests:** Where TCP is heavily filtered, targeted UDP probes or direct application-layer requests (e.g. issuing an HTTP request on a suspected web port) can confirm whether a service is actually listening.
- **Passive reconnaissance / OSINT:** DNS records, Shodan/Censys lookups, certificate transparency logs, and WHOIS data can reveal services that active scanning cannot see through heavy filtering.

Q4. Compare TCP, UDP, and stealth (SYN) port scanning techniques. In which scenarios would each be the most effective, and what are their advantages and limitations?

Answer:

TCP Connect, UDP, and SYN (stealth) scans probe the network stack in fundamentally different ways, which affects their accuracy, speed, detectability, privilege requirements, and the type of services each is best suited to discover. Understanding these trade-offs is essential to choosing the right technique for a given assessment scenario.

Technique	How it works	Advantages	Limitations	Best scenario
TCP Connect (-sT)	Completes the full three-way handshake using the OS connect() call.	Reliable and accurate; no raw-socket privileges needed; works from any user account or restricted environment.	Slower; every connection is fully logged by the target application, making it easily detected and traceable back to the source.	Unprivileged scanning, or when accuracy matters more than stealth (e.g. authorized internal compliance audits).

SYN / Stealth (-sS)	Sends SYN, evaluates the SYN-ACK/RST response, then sends RST instead of completing the handshake ("half-open" scan).	Fast; less likely to be logged at the application layer (no full session is ever established); good balance of speed and stealth; nmap's default scan type.	Requires raw-socket (root/admin) privileges; still detectable by modern IDS/IPS/NGFW; can be blocked or skewed by stateful firewalls.	Default choice for authorized penetration tests where speed and a reduced logging footprint both matter.
UDP (-sU)	Sends UDP packets and infers state from ICMP port-unreachable responses or protocol-specific replies (no handshake concept in UDP).	The only way to discover UDP-based services (DNS, SNMP, DHCP, NTP, TFTP) that TCP scans cannot see at all.	Very slow (often 10–20x slower than TCP scans); ambiguous results since no response can mean open OR filtered; frequently throttled by ICMP rate limiting on the target.	Assessing UDP-based infrastructure such as DNS resolvers, SNMP-managed devices, or VoIP/NTP services.

Other Scan Variants Worth Knowing

- **FIN, NULL, and Xmas scans (-sF, -sN, -sX):** Send unusual TCP flag combinations to try to slip past simple packet-filtering firewalls; rely on RFC 793 behaviour and generally fail against modern stacks like Windows, which respond to all these probes with RST regardless of state.
- **ACK scan (-sA):** Does not determine open/closed but is excellent for mapping firewall rulesets and distinguishing stateful from stateless filtering.
- **Idle/Zombie scan (-sI):** Achieves a fully blind scan by using a third-party host's predictable IP ID sequence, hiding the true scanner's identity almost completely.

Overall, SYN scans are generally preferred for fast, relatively stealthy authorized assessments of TCP services; TCP Connect scans are used when raw-socket access is unavailable or a fully verified connection is required; and UDP scans, despite being slow and less precise, are essential whenever UDP-based services must be assessed, since neither TCP technique can detect them at all.

Q5. Suppose you are conducting an authorized security assessment and discover critical services (such as SSH, FTP, and database ports) exposed to the internet. How would you assess the risks and recommend mitigation strategies?

Answer:

Internet-exposed administrative and data services are consistently among the highest-risk findings in any assessment, because they are directly reachable by anyone on the internet – including automated scanners, botnets, and credential-stuffing tools – and often provide either remote command execution or direct access to sensitive data. Numerous real-world breaches have started precisely from an exposed database or FTP service left reachable from the internet, which is why this class of finding is treated with particular urgency.


```
Internet-exposed critical services (sample)

$ nmap -sV -p 21,22,3306,5432 203.0.113.50 (internet-facing host)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.5 (anonymous login: enabled)
22/tcp    open  ssh      OpenSSH 6.6.1 (password auth: enabled)
3306/tcp  open  mysql    MySQL 5.6. (bind-address 0.0.0.0)
5432/tcp  open  postgres PostgreSQL 9.3 (no SSL enforced)

Risk flags: anonymous FTP, DB ports reachable from WAN,
password-only SSH, no TLS on DB traffic.
Recommended: VPN/bastion access only, disable anonymous FTP,
key-based SSH + MFA, restrict DB to internal subnet, enforce TLS.
```

Fig. 4 - Sample scan of internet-facing critical services with risk flags and recommendations (illustrative)

Risk Assessment Approach

- **Confirm exposure:** Verify the service is genuinely reachable from outside the network (not just flagged by an internal scan), and identify the exact version and configuration in use.
- **Check authentication strength:** Test, within the rules of engagement, for default credentials, weak/guessable passwords, or anonymous/guest access – especially common on FTP and database services.
- **Check for known vulnerabilities:** Match the service version against CVE databases for remote code execution, authentication bypass, or information-disclosure vulnerabilities.
- **Assess data sensitivity:** Determine what data the service can reach – a database port exposing customer PII or financial records is a critical/high risk regardless of patch level.
- **Evaluate encryption in transit:** Check whether traffic is sent in cleartext (e.g. plain FTP, unencrypted database connections) versus encrypted (SFTP/FTPS, SSH with strong ciphers, TLS-enabled database connections).
- **Consider attacker reconnaissance value:** Even a fully patched, well-configured exposed service still gives attackers a foothold to fingerprint the organization and attempt credential stuffing or brute-force attacks over time.
- **Regulatory and compliance exposure:** Consider whether the exposed service falls under compliance regimes such as PCI-DSS (cardholder data), HIPAA (health data), or GDPR (personal data of EU residents), which impose specific controls and breach-notification obligations.
- **Assign an overall risk rating** (Critical/High/Medium/Low) combining likelihood of exploitation (ease of attack, presence of public exploits, weak credentials) with business impact (data sensitivity, service criticality, downtime cost).

Recommended Mitigation Strategies

- **Remove unnecessary internet exposure first:** Where the service does not need to be public, restrict it behind a VPN, bastion/jump host, or firewall ACL limited to specific trusted IP ranges – this single change eliminates most opportunistic attacks.
- **Enforce strong authentication:** Disable default/anonymous accounts, enforce strong password policies, and require key-based authentication for SSH plus multi-factor authentication wherever supported.
- **Patch and harden services:** Update to the latest stable, supported version and apply vendor hardening guides (disable weak ciphers, disable root/administrator remote login, disable legacy protocol

support such as SSLv3/TLS 1.0).

- **Replace insecure protocols:** Migrate plain FTP to SFTP/FTPS, and ensure database connections enforce TLS in transit rather than allowing cleartext fallback.
- **Apply network segmentation:** Place databases and administrative services in an internal or restricted network segment rather than directly in the internet-facing DMZ; use a reverse proxy or API gateway for anything that genuinely must be public.
- **Add monitoring and alerting:** Deploy IDS/IPS and centrally log failed authentication attempts (SIEM) to detect brute-force or scanning activity against these services in near real time.
- **Rate-limit and lock out:** Configure account lockout or connection throttling (e.g. fail2ban) after repeated failed login attempts to slow down brute-force attacks.
- **Principle of least privilege:** Ensure database accounts used by applications have only the minimum permissions required, and separate administrative accounts from application service accounts.
- **Formal change and re-test cycle:** Document the finding, assign an owner and remediation timeline based on the risk rating, and re-scan after remediation to confirm the exposure is genuinely closed.

In summary, the assessment should combine exposure verification, credential and vulnerability testing, and business-impact/compliance analysis to produce a defensible risk rating, followed by a mitigation plan that prioritizes reducing unnecessary exposure, strengthening authentication, and encrypting data in transit for the highest-risk services first.